

PrivacyTrace

面向普通 Android 用户的 App 隐私体检工具——把专业级、多源、可追溯的隐私证据，转化为普通用户能理解、能复核的隐私报告。

文档版本

v0.1

日期

2026-10-01

文档性质

组内审阅稿

用途

项目组交接 · 开发启动 · PRD 基础稿

本稿用于项目组内部交接与开发启动讨论，是后续 PRD、任务看板与开发排期的**基础稿**。

文中所有结论均为待审阅状态，欢迎直接在页面上标注修改意见。

CONTENTS

全文 18 节，建议按 Part 1 → 4 顺序阅读。

Part 1 • 项目定位与创新叙事

- 1 项目定位
- 2 第一目标用户与核心场景
- 3 第一创新叙事

定义「我们做什么、为谁做、凭什么算创新」——三个问题必须先对齐，后面的技术方案才有落点。

Part 2 • MVP 范围与技术架构

- | | |
|---------------------|------------|
| 4 Core MVP 最小闭环 | 17 推荐开发顺序 |
| 5 MVP 核心模块 (P0 十二项) | 18 第一开发里程碑 |
| 6 动态分析定位 (P1 增强) | |

本部分是**开发排期的直接依据**：什么必须做、什么可以冻结、先做什么。第 6 节与第 18 节的「禁止抢跑」条款请重点确认。

Part 3 • 数据模型与核心机制

- | | |
|-------------------------|-------------|
| 7 Privacy Behavior 数据模型 | 11 核心问题类型 |
| 8 Privacy Taxonomy | 12 产品界面三层结构 |
| 9 多源 Policy 模型 | |
| 10 Policy 模糊性检测 | |

自研内核所在：Taxonomy → Evidence Model → Consistency Engine。第 7 节「事实 / 声明 / 推断分开存」是全项目最关键的设计约束。

Part 4 • 验证与任务拆解

13 样本计划

14 用户实验

15 MVP 成功标准

16 MVP 任务拆解 (13 个 Epic)

A 附录 · 审阅速查

验收标准与工作量边界。第 16 节的 Epic 编号建议直接同步进任务看板，作为 PT-xxx 工单编号来源。

审阅方式建议

先读 Part 1 确认项目定位无偏差 → 重点审 Part 2 的范围裁剪（哪些砍掉、哪些冻结）→ 认领 Part 4 的任务编号。技术细节（Part 3）如有异议请直接在对应小节标注。

资源地图：谁在什么时候需要什么

本文档结构较密，先按「角色 → 重点章节」建立索引，避免全文硬啃。

角色	必读章节	关注点
全体组员	1 · 3 · 4 · 15 · 18	项目一句话是什么、创新点表述、MVP 边界、成功标准、第一里程碑
后端 / 分析	5 · 7 · 8 · 9 · 10 · 11 · Epic 1–7	Evidence Model、Taxonomy、Consistency Engine 的状态机与规则边界
前端 / 界面	12 · 5 (PT-801~807) · Epic 8–9	三层界面结构、自然语言模板、证据下钻的「2–3 次点击」目标
实验 / 评测	13 · 14 · 15 · Epic 10–12	样本获取渠道、对照组设计、指标定义与 Ground Truth 建法
文档 / 答辩	1 · 3 · 15 · A	创新叙事口径、验收话术、术语统一（避免与竞品表述混淆）

术语速查表

全文共出现下列固定术语，含义以本表为准，避免组内表述漂移。

Evidence / 证据 支撑某条结论的原始来源片段，必须可追溯到文件、类、方法或政策原句。所有结论都要绑定 Evidence IDs。	PrivacyBehavior 最小核验单元。由 DataType、Action、Purpose、Recipient、Transfer、TemporalScope 与 Evidence[] 共同描述。
Taxonomy 隐私数据分类体系。MVP 控制在约 8 个一级类，支持上位 / 下位类，并提供 Permission / API / Policy Phrase 三向映射。	Static Evidence 静态分析结果，统一称为「潜在行为 / 静态证据」。不等于「App 实际收集了数据」。
Observed Evidence 动态分析结果，统一称为「运行时已观察行为」。由 P1 动态模块把静态潜在行为升级而来。	EXACT_MATCH 政策表述与程序行为在数据类型层面完全对应，属于声明充分的情况。
CATEGORY_MATCH 政策只写到上位类别（如只写「设备信息」），程序出现具体类型（如 OAID）。既非完全匹配，也非完全未声明。	NOT_DECLARED 该数据类型的访问行为在对应政策源中找不到任何相关表述。
POLICY_SOURCE_CONFLICT 同一 App 的多个政策源之间结论不一致（如 App 内未声明、商店却有声明）。	AMBIGUOUS_DISCLOSURE 政策有相关表述但过于笼统，无法据此确认具体数据类型、目的或接收方。
INSUFFICIENT_EVIDENCE 当前证据不足以支撑任何结论。必须如实输出，不可用推测填补。	多源 Policy IN_APP_POLICY / STORE_POLICY / OFFICIAL_WEB_POLICY / SDK_POLICY 四个来源，分别核验、不合并为一份。
Ground Truth Controlled Benchmark 中人工确认的正确答案，用于自动评测 Precision / Recall / F1。	AnalysisJob 一次完整分析任务的运行实例，承载输入 APK、规则集版本、各阶段产物与状态流转。

措辞红线（全体必须遵守）

以下表述**不得出现在任何界面、报告、答辩材料中**：

× 把「存在权限 / API」直接写成「App 实际收集了数据」；× 输出「违法 / 合法」总裁决；× 输出「安全 / 不安全」总裁决；× 输出「建议卸载」类行动建议；× 把模型推断出的 Purpose 当作已确认事实陈述。

正确替换：静态结果说「检测到代码中存在.....的能力」；政策问题说「这份政策只写了.....，没有明确说明.....」。

我们做什么，为谁做，凭什么算创新

01

项目定位

PrivacyTrace 是面向普通 Android 用户的 App 隐私体检工具。

它通过分析 APK 中的隐私行为证据，并与 App 的隐私政策、应用商店声明等信息进行一致性核验，将专业隐私证据转化为普通用户能够理解、能够下钻复核的隐私报告。

核心表达

01

Android 权限告诉用户：App 被允许做什么

02

隐私政策 / 商店声明告诉用户：App 声称自己做什么

03

PrivacyTrace 尝试告诉用户：程序中存在什么隐私行为证据，以及这些行为是否被清楚声明

证据措辞原则

应该这样写

- 静态分析结果 → 潜在行为 / 静态证据
- 动态分析结果 → 运行时已观察行为

不能这样写

- 把「存在权限 / API」表述成「App 实际收集了数据」
- 直接输出「违法 / 合法」「安全 / 不安全」「建议卸载」等总裁决

第一目标用户与核心场景

第一目标用户

普通 Android 用户 核心需求：

我常用的这个 App 可能访问什么数据？这些事情它有没有跟我说清楚？

次级用户

- Android 开发者
- 隐私 / 安全审查人员

核心用户任务

主任务：**App 隐私体检**

延伸场景：

- 安装前查看某 App 的隐私行为报告
- 授权位置、通讯录、相机等权限前查看隐私影响
- 开发者检查代码行为与政策是否一致

第一创新叙事

口径说明

PrivacyTrace 不主张首次提出「代码行为与隐私政策一致性分析」。所有答辩、申报、宣传材料中的创新点表述必须与此一致。

第一原创贡献应表述为：

把专业级、多源、可追溯的隐私证据，
转化为普通用户能理解、能复核的 **App 隐私体检**。

创新结构

产品层主创新

- 普通用户可理解的隐私体检
- 低技术门槛的解释
- 分层可视化与证据下钻

技术层支撑

- 统一 Privacy Taxonomy
- 统一 Evidence Model
- 行为证据与多源 Policy 的一致性核验
- 证据链组织与解释

什么必须做，什么可以冻结

04

Core MVP • 最小可交付闭环

STEP 1
APK

→

STEP 2
静态隐私
证据

→

STEP 3
多源
Privacy
Policy

→

STEP 4
一致性
核验

→

STEP 5
普通用户
可视化报
告

→

STEP 6
证据
下钻

范围红线

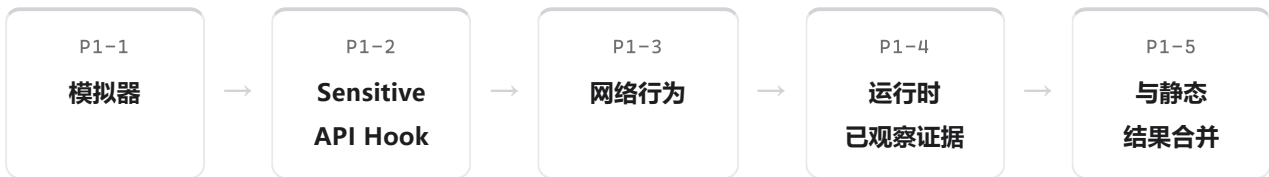
Core MVP 必须成立，即使动态分析未完成。动态分析定位为增强能力，不是 PrivacyTrace 成立的必要条件。

MVP 核心模块 (P0 必须完成)

#	模块	关键要求
1	APK Intake	导入 APK; 读取包名、版本、SHA-256、来源等基础元数据
2	Manifest Parser	权限、组件、基础配置
3	Sensitive API Scanner	识别主要敏感 API; 映射至隐私数据类型; 保留文件 / Class / Method 等证据位置
4	SDK Detector	识别主要第三方 SDK; 保留 Vendor / SDK / Evidence 信息; 不因「存在 SDK」直接声称其收集数据
5	Privacy Taxonomy	建立 canonical 隐私数据分类; 支持上位类 / 下位类; 支持 Permission / API / Policy Phrase 映射
6	Policy Collector	IN_APP_POLICY STORE_POLICY OFFICIAL_WEB_POLICY SDK_POLICY
7	Policy Parser	LLM 负责文本切分、结构化、候选解释; 规则负责最终事实判定
8	Consistency Engine	输出 EXACT_MATCH / CATEGORY_MATCH / NOT_DECLARED / POLICY_SOURCE_CONFLICT / AMBIGUOUS_DISCLOSURE / INSUFFICIENT_EVIDENCE
9	Evidence Model	所有结论必须能回到原始证据
10	User Report	普通用户自然语言解释; 不显示技术状态码作为主界面内容
11	Evidence Drill-down	Manifest / API / SDK / Policy 原句
12	Benchmark	Controlled Benchmark + Real-world Benchmark

动态分析定位

P1 增强能力 —— 不是成立条件



动态模块的作用：

将「静态发现的潜在行为」升级为「运行时已观察行为」。

如果工期不足

可以整体冻结动态分析 Epic。

明确禁止

静态主链路未打通，却先投入大量时间折腾 Frida、污点分析、反调试。

自研内核：Taxonomy → Evidence → Consistency

07

Privacy Behavior 数据模型

最小核验单元：

PrivacyBehavior

└─

DataType

└─

Action

└─

Purpose

└─

Recipient

└─

Transfer

└─

TemporalScope

└─

Evidence[]

示例：

DataType: Precise Location

Action: Access

Purpose: Navigation

Recipient: First Party

Transfer: Unknown

TemporalScope: While In Use

Evidence:

- ACCESS_FINE_LOCATION

- LocationManager API

- Policy Sentence #17

关键原则

全项目最关键设计约束

事实、声明、推断必须分开存。

事实

DECLARED_PURPOSE

推断

CONTEXTUAL_PURPOSE_HINT

未知

UNKNOWN

不能把模型推断出的 Purpose 当作已确认事实。

Privacy Taxonomy

MVP 建议控制在约 8 个一级类：

一级类别	说明 / 典型下位类型
Location	位置类，含精确位置 / 粗略位置
Contacts	通讯录与联系人相关数据
Device Identifier	设备标识符，含 Android ID / OAID / IMEI
Camera	相机相关能力与数据
Microphone	麦克风录音相关能力与数据
Files & Media	文件与媒体内容
Account / Identity	账号与身份信息
Device / Usage Information	设备与使用行为信息

层级示例：

```
Device Information
├── Device Identifier
│   ├── Android ID
│   ├── OAID
│   └── IMEI
```

Policy Match

EXACT_MATCH

CATEGORY_MATCH

NOT_DECLARED

典型判定示例

Policy 只写「设备信息」，程序出现 OAID。

应判：**CATEGORY_MATCH** —— 而不是完全匹配，也不是完全未声明。

多源 Policy 模型

同一个 App 的政策**不合并为一份**：

SOURCE 1
IN_APP_POLICY

SOURCE 2
STORE_POLICY

SOURCE 3
OFFICIAL_WEB_POLICY

SOURCE 4
SDK_POLICY

宿主多源政策 · 分别核验

```
IN_APP_POLICY:      NOT_DECLARED
STORE_POLICY:       DECLARED
OFFICIAL_WEB_POLICY: DECLARED
```

产生：

POLICY_SOURCE_CONFLICT —— 同一 App 在不同渠道给出了不一致的隐私声明。

SDK Policy

第三方 SDK 自己的政策**不能替宿主 App 补声明**。

Policy 模糊性检测

LLM 做结构化，规则做最终判定。

重点检测维度

- DataType Specificity
- Purpose Specificity
- Recipient Specificity
- Action Specificity
- Scope Specificity
- Catch-all Clause

普通用户层解释示例

「这份政策只写了『合作伙伴』，没有明确说明数据具体发送给谁。」

核心问题类型

MVP 不做总风险分数。核心问题类型先控制在：

- Undeclared Data Access
- Policy Granularity Gap
- Unclear Third-party Recipient
- Policy Source Conflict
- Ambiguous Policy Statement
- Version Mismatch
- Insufficient Evidence

动态模块完成后可增加：

- Observed Undeclared Access
- Undeclared Third-party Transfer
- Permission / Behavior Conflict

所有问题都必须绑定 **Evidence Status**。

产品界面结构

第一层 • 隐私体检概览

用户先看自然语言结论。示例：

- 「检测到代码中存在读取精确位置的能力。」
- 「App 内隐私政策只笼统说明『位置信息』，没有具体说明数据类型。」
- 「检测到第三方地图 SDK，但目前证据不足以确认位置数据实际发送给该服务。」

第二层 • Privacy Consistency Matrix

隐私数据	潜在访问	第三方	政策	当前结论
精确位置	是	地图 SDK	类别声明	声明粒度不足
通讯录	是	未发现	未声明	潜在访问未声明
OAID	是	广告 SDK	模糊	第三方声明不足

第三层 • Evidence

Manifest

→

ACCESS_FINE_LOCATION

Code

→

LocationManager.getLastKnownLocation()

SDK

→

xxx-map-sdk

Policy

→

「我们可能收集位置信息……」

目标：任何结论最多 2-3 次点击能看到依据。

怎么证明有效，活怎么分

13

样本计划

Real-world Benchmark

共 7 个真实 App：

- 5 个 Representative
- 2 个 Challenge

样本来源：各 App 的主要官方发行渠道

分析对象：

App × 主要官方渠道 × 指定版本

Controlled Benchmark

20–30 个行为测试用例。至少覆盖：

- EXACT_MATCH / CATEGORY_MATCH / NOT_DECLARED
- Policy 模糊 / Policy 冲突
- Permission Evidence
- Sensitive API Evidence
- SDK Evidence
- 静态存在 / 动态确认
- 静态存在 / 动态未触发
- 动态发现 / 静态漏检
- 原文外传
- 编码 / Hash 外传
- SDK 第三方传输

用户实验

目标：

证明 PrivacyTrace 不只是「界面更漂亮」，而是确实降低普通用户理解隐私行为的门槛。

测试对象

- 非项目组成员
- 排除安全 / 隐私专业背景
- 可以包含计算机相关专业学生

对照组

Android 权限 + 原始 Privacy Policy

实验组

PrivacyTrace 报告

指标

指标	含义
理解正确率	被试回答问题与 Ground Truth 的一致程度
完成时间	完成同一组理解任务所耗时长
主观理解度	被试自评对 App 隐私行为的理解程度
是否能定位到证据	能否在报告中找到支撑结论的原始依据

MVP 成功标准

只有两个核心标准。

技术有效性

在真实 App 中能够发现
行为证据 ↔ **隐私声明**
之间有意义、可复核的差异。

用户有效性

普通用户通过 PrivacyTrace，相比 Android 权限列表 + 原始隐私政策，能更准确、更快地理解下列事项。

- App 涉及哪些隐私数据
- 是否涉及第三方
- 政策是否说明清楚
- PrivacyTrace 为什么得出这个结论

MVP 任务拆解 · 13 个 Epic

任务编号建议直接同步进任务看板，作为 PT-xxx 工单编号来源。带 **核心** 标记者为自研内核，**不建议外包或削减**。

EPIC 0 项目骨架

P0

- PT-001 Repository / Monorepo
- PT-002 Backend 基础项目
- PT-003 Frontend 基础项目
- PT-004 Database Schema
- PT-005 AnalysisJob 数据结构
- PT-006 Sample App 管理

EPIC 1 APK 基础分析

P0

- PT-101 APK Metadata
- PT-102 packageName / versionCode / versionName
- PT-103 SHA-256
- PT-104 Manifest 提取
- PT-105 Permission 解析
- PT-106 Component 解析
- PT-107 Error Handling

EPIC 2 Privacy Taxonomy

内核

- PT-201 一级类别
- PT-202 二级数据类型
- PT-203 Permission → DataType
- PT-204 API → DataType
- PT-205 Policy Phrase → DataType
- PT-206 Ruleset Versioning

EPIC 3 Sensitive API Scanner

P0

- PT-301 DEX / 反编译结果读取
- PT-302 Sensitive API Ruleset
- PT-303 API 调用位置提取
- PT-304 Class / Method 信息
- PT-305 DataType Mapping
- PT-306 Evidence JSON

第一版目标：证明「这里存在某类隐私数据访问的代码证据」。不是完整污点分析。

EPIC 4 SDK Detection

P0

- PT-401 SDK Signature Schema
- PT-402 常见 SDK Signature
- PT-403 SDK Detection
- PT-404 SDK → Vendor
- PT-405 SDK → Potential DataType
- PT-406 SDK Evidence

EPIC 5 Policy Pipeline

P0

PT-501 PolicyDocument Schema

PT-502 Policy Source Type

PT-503 Snapshot

PT-504 Policy Hash

PT-505 文本切分

PT-506 LLM Structure Extraction

PT-507 DataType Normalization

PT-508 Purpose Extraction

PT-509 Recipient Extraction

PT-510 Policy Sentence Evidence

EPIC 6 Policy Ambiguity Rules

内核

PT-601 DataType Specificity

PT-602 Purpose Specificity

PT-603 Recipient Specificity

PT-604 Catch-all Clause

PT-605 Category vs Exact Match

PT-606 POLICY_SOURCE_CONFLICT

EPIC 7 Consistency Engine • PrivacyTrace 最重要的自研模块

内核

输入

CodeEvidence[]
PolicyClaim[]
Taxonomy
Ruleset

输出

PrivacyIssue[]

PT-701 EXACT_MATCH

PT-702 CATEGORY_MATCH

PT-703 NOT_DECLARED

PT-704 Policy Source Conflict

PT-705 Ambiguous Disclosure

PT-706 Insufficient Evidence

PT-707 Evidence Status

PT-708 Explanation Generator

所有结果必须是 **规则结果 + Evidence IDs**。不能只生成一段 LLM 自然语言。

EPIC 8 普通用户报告

P0

PT-801 App Report 首页

PT-802 Privacy Consistency Matrix

PT-803 DataType Detail

PT-804 Issue Detail

PT-805 Policy Explanation

PT-806 Natural Language Template

PT-807 Evidence Drill-down

EPIC 9 Evidence Explorer

P0

PT-901 Manifest Evidence

PT-902 Code / API Evidence

PT-903 SDK Evidence

PT-904 Policy Sentence Evidence

PT-905 Evidence Relationships

PT-906 Timeline / Graph

EPIC 10 Controlled Benchmark

P0

PT-1001 Benchmark Test App

PT-1002 Ground Truth Schema

PT-1003 20-30 Test Cases

PT-1004 Automated Evaluation

PT-1005 Precision / Recall / F1

PT-1006 Error Analysis

EPIC 11 Real-world Benchmark

P0

PT-1101 样本选择

PT-1102 官方渠道获取

PT-1103 版本记录

PT-1104 Policy 收集

PT-1105 系统分析

PT-1106 人工复核

PT-1107 Case Study

EPIC 12 用户实验

P0

PT-1201 测试问题设计

PT-1202 用户任务设计

PT-1203 理解正确率

PT-1204 完成时间

PT-1205 主观理解度

PT-1206 结果分析

P1 Dynamic Analysis

可整体冻结

PT-D01 标准 Android 模拟器

PT-D02 Sensitive API Hook

PT-D03 Network Capture

PT-D04 RAW_MATCH

PT-D05 TRANSFORM_MATCH

PT-D06 Third-party Endpoint

PT-D07 Dynamic Evidence Model

PT-D08 Static / Dynamic Merge

Core MVP 未跑通前禁止抢跑。

推荐开发顺序

01 **Taxonomy** — 先定分类体系，后续映射才有落点

02 **APK Parser**

03 **Sensitive API / SDK Evidence**

04 **Policy Parser**

05 **Consistency Engine** — 自研内核

06 **User Report**

07 **Benchmark**

08 **Dynamic Enhancement** — 最后，可冻结

真正的项目主线

Evidence Model → Taxonomy → Consistency Engine → Explainable Report

不是前端，也不是 FlowDroid。

第一开发里程碑

先只打通一个真实样本。

M1

一个真实 APK

M2

Permission + Sensitive API

M3

一份真实 Privacy Policy

M4

结构化 Policy Claims

M5

Consistency Engine

M6

3-5 条可解释结果

M7

点击结果看到代码证据 + Policy 原句

第一里程碑完成标准

只要这个闭环稳定跑通，PrivacyTrace 才算真正进入可持续开发阶段。

在此之前，不投入大量时间到

• 复杂 Dashboard

• 动态分析

• Frida

• 污点分析

• 大规模样本

• 炫技式关系图

附录 A

审阅速查

本稿的三个「不可动摇」

1. 措辞红线 —— 不把静态证据说成实际收集，不下合法/违法、安全/不安全、建议卸载的裁决。

2. 事实 / 声明 / 推断分开存 —— 推断出的 Purpose 永远不能当已确认事实用。

3. 所有结论绑定 Evidence IDs —— 不能只生成一段 LLM 自然语言就交付。

本稿的三个「可协商」

1. **动态分析整体冻结** —— 工期不足时 P1 可整体砍掉，不影响 MVP 成立。
2. **Taxonomy 一级类数量** —— MVP 建议约 8 个，可依实际样本调整。
3. **样本规模** —— Real-world 暂定 7 个（5 代表 + 2 挑战），Controlled 暂定 20–30 用例。

建议在本次审阅中确认的事项

- 「第一创新叙事」的表述是否获得全组一致认可（涉及后续所有对外材料）。
- 第一里程碑的样本 App 是否已选定，由谁负责获取与版本冻结。
- Taxonomy 初始规则集由谁维护、Ruleset Versioning 如何协作。
- 13 个 Epic 的人员认领与优先级排序。
- 用户实验的被试来源与时间窗口。